

VulneraSight AI — Getting Started

A plain-English guide to setting up the app and running your first analysis. You'll need to use a terminal (Command Prompt / PowerShell on Windows, Terminal on macOS or Linux), but every command is copy-paste.

What you'll need (5 minutes)

- 1. **Node.js, version 18 or newer** — this runs the app. Download it from <https://nodejs.org> (pick the "LTS" version) and install it. To check it worked, open a terminal and run `node -v`; if you see version 18 or higher (e.g. `v20.x.x`), you're good.
- 2. **The project files** — the `vulnerasight` folder (unzip `vulnerasight-webapp.zip` if you haven't already).
- 3. **An API key** from ONE AI provider. You only need one. See the table below.

Provider	Where to get a key
Anthropic (Claude)	https://console.anthropic.com → API Keys → Create Key
Ask Sage	Your Ask Sage account → user/API settings → create an API key (use the instance your organization approved)
Google Gemini	https://aistudio.google.com → Get API key
OpenAI / Azure	Your OpenAI or Azure OpenAI account → API keys

Keep this key private — treat it like a password. It stays on your computer and is never shown in the browser.

Step 1 — Open the project in a terminal

Open your terminal and move into the project folder. For example:

```
bash
cd path/to/vulnerasight
```

(Tip: type `cd` with a space, then drag the `vulnerasight` folder into the terminal window to fill in the path, then press Enter.)

Step 2 — Install the app's components

Run this once. It downloads everything the app needs (takes a minute or two):

```
bash  
  
npm install
```

Step 3 — Create your settings file

Make a copy of the example settings file and name it `.env`:

```
bash  
  
# macOS / Linux  
cp .env.example .env  
  
# Windows (Command Prompt)  
copy .env.example .env
```

Step 4 — Choose your provider and paste your key

Open the new `.env` file in any text editor (Notepad, TextEdit, VS Code...). Set two lines: which provider to use, and your key. Pick the block that matches you:

Anthropic (Claude):

```
ini  
  
AI_PROVIDER=anthropic  
AI_API_KEY=sk-ant-your-key-here
```

Ask Sage:

```
ini  
  
AI_PROVIDER=asksage  
AI_API_KEY=your-asksage-key-here  
AI_MODEL=gpt-4.1-mini
```

Google Gemini:

```
ini
```

```
AI_PROVIDER=gemini  
AI_API_KEY=your-gemini-key-here  
AI_MODEL=gemini-2.5-flash
```

Save the file and close it.

- **AI_MODEL** is optional — leave it out to use the default. Set it to any model your account actually offers (Ask Sage instances and Gemini both change their model lineup over time).
- **Ask Sage on GovCloud / a special instance?** Add one more line pointing at your instance, e.g.: `AI_BASE_URL=https://api.asksage.ai/server/openai/v1` (only the middle part of the address changes per instance — use the one your organization approved).

Step 5 — Start the app

```
bash
```

```
npm run dev
```

Wait a few seconds, then open your browser to:

👉 <http://localhost:5173>

You should see the VulneraSight dashboard with **"Engine ready"** in the top-right. Leave the terminal window open while you use the app. To stop it later, click the terminal and press `Ctrl + C`.

Want to confirm your key is set up? Visit <http://localhost:8787/api/health>. It shows your provider, model, and `"keyConfigured": true` if the key was read correctly.

Using the app

The screen has a **control panel on the left** and **results on the right**.

1. Load your scan files

In the **Ingestion** box, drag and drop your files onto the dropzone, or click it to browse. You can add both at once:

- a Nessus scan — a `.nessus` file

- a STIG checklist — a `.ckl` file

The two chips (NESSUS and **STIG CKL**) light up teal as each file is recognized, and you'll see a count like *"Parsed 9 findings."* You don't need both — one file works fine — but using both lets the app correlate them.

Just exploring? Click **Load demo dataset** to fill in realistic sample data so you can try everything without your own files.

2. Set the operational context

This is what makes the analysis meaningful — the same vulnerability is judged very differently depending on how the system is connected.

- **Connectivity Profile** — pick the one that matches the system (from *Standalone, No Media* through *Open / Connected Network*). An internet-facing remote exploit is treated as critical; on an air-gapped box it's de-rated, while local and USB/media weaknesses rise.
- **Cybersecurity Budget** — Low / Medium / High. Tighter budgets push expensive, non-critical fixes further down the schedule.
- **Remediation Capacity** — Urgent / Standard / Constrained — your team's available effort.
- **Data masking** — leave this **on** (recommended) to redact IP addresses and hostnames before anything is sent to the AI provider.

3. Run the analysis

Click **Run threat analysis**. It takes a few seconds. The results appear on the right in three sections.

4. Read the results

§1 Executive Summary & Threat Posture — an overall risk dial, three threat-actor scores (**Insider** / **Near-Peer** / **Outsider**), and a written summary mapping weaknesses to MITRE ATT&CK techniques and explaining how the connectivity affects your risk. Below it, the **Threat Posture Matrix** radar shows where you're most exposed.

§2 Prioritized Remediation Roadmap — every finding sorted into **Immediate** → **Phase 1** → **Phase 2** → **Defer**. Use the tabs to filter by tier. Each card shows the real (context-adjusted) risk and how the raw CVSS score changed once connectivity was factored in. Click any finding to open its detail drawer.

§3 Tradespace Planner — a chart of *impact vs. effort*. The highlighted top-left band is your "quick wins" (high impact, low effort). Drag the **effort** and **budget** sliders to gray out items that exceed your limits and focus on what's realistic now.

5. Get your POA&M language

Click any finding (in the roadmap or on the chart) to open the side drawer. It gives you ready-to-use **Plan of Action & Milestones** text:

- **Compensating Control** — what to do right now to reduce risk without patching
- **POA&M — Impact, Mitigation, and Milestones** language
- relevant **MITRE ATT&CK** technique tags

Use the **copy** button on each block to paste it into your documentation.

6. Export everything

In the roadmap header, click **Export POA&M (.csv)** to download a spreadsheet of all findings with their priorities, risk levels, and POA&M text.

Tip: try different scenarios

After running once, change the **Connectivity Profile** and watch the radar, risk levels, and priorities update instantly. The numbers recompute live; if you want the *written* summary and POA&M text rewritten for the new context, click **Re-run analysis**.

Running it "for real" (optional)

`npm run dev` is for everyday use on your own machine. To run it as a single always-on service (e.g. on a shared server):

```
bash

npm run build      # prepares the optimized version
npm start          # serves the whole app on one address
```

Then open **<http://localhost:8787>**. Set `PORT=8787` to a different number in `.env` if that address is taken.

Troubleshooting

What you see	What to do
--------------	------------

"Server is missing an API key..."

Your `.env` has no key. Re-check Step 4 — `AI_API_KEY` must be filled in, and the file must be named exactly `.env` (not `.env.txt`). Restart with `Ctrl+C` then `npm run dev`.

What you see	What to do
<i>"The analysis service is busy right now..."</i>	The provider is rate-limited or overloaded. Wait ~10 seconds and click Run again.
<i>"...response wasn't valid structured data..."</i>	A one-off hiccup. Just run it again — it almost always works on retry.
Amber note: <i>"some findings were not included" / "response may be cut short"</i>	Not an error — the analysis succeeded. The app sends the highest-severity findings and lets you know if some were left out or the reply was long.
Wrong file in the wrong slot	The app sorts files by their <code>.nessus</code> / <code>.ckl</code> extension. Make sure your files have the correct extension.
Browser shows nothing / can't connect	Make sure the terminal running <code>npm run dev</code> is still open, and you're using http://localhost:5173 (not https).
<i>"command not found: npm"</i>	Node.js isn't installed (or the terminal was opened before installing). Install from https://nodejs.org , then open a new terminal.
Port already in use	Something else is using the port. Close other dev servers, or set a different <code>PORT</code> in <code>.env</code> .
Check what's configured	Visit http://localhost:8787/api/health to see the active provider, model, and whether your key was detected.

A note on the results

The risk scoring and threat posture are calculated deterministically from your scan data and chosen context. The written summaries and POA&M language are AI-generated drafts — always have an analyst review them before using them in official documentation.